



40 DAYS OF OFFENSIVE SECURITY

A Structured Practice Roadmap

#40DaysOfOffSec | Daily Dark Team

Flexible pacing — 40 days does not mean 40 consecutive days. Complete modules in any order that suits your schedule. All resources are freely available unless otherwise noted. Platform accounts required: TryHackMe, HackTheBox, PortSwigger Academy, OffSec PG.

Phase 1	Days 1–5	Foundations
Phase 2	Days 6–14	Web Exploitation
Phase 3	Days 15–24	Infrastructure & AD
Phase 4	Days 25–33	HTB & Platform Challenges
Phase 5	Days 34–40	Advanced Topics & Capstone

PHASE 1 // Foundations — Tools, OS & Networking Basics

DAY 01 — OWASP Top 10 — Core Web Vulnerabilities

Web

Understand the ten most critical web application security risks including injection, broken authentication, XSS, and insecure deserialization. Build mental models for each class before touching a lab.

RESOURCES

[TryHackMe – OWASP Top 10 Room](#)

[OWASP Official Documentation](#)

[PortSwigger Web Security Academy](#)

DAY 02 — OWASP Juice Shop — Hands-On Web Exploitation

Web

Deliberately vulnerable Node.js app covering XSS, SQLi, IDOR, broken auth, and more. Score-board driven; aim to solve at least one challenge in every category.

RESOURCES

[TryHackMe – OWASP Juice Shop](#)

[Juice Shop Official Docs](#)

[Juice Shop Challenge Hints](#)

DAY 03 — Linux Fundamentals & Privilege Escalation Basics

Linux

Master file permissions, SUID/SGID bits, cron jobs, writable paths, and sudo misconfigurations. Practice with GTFOBins for living-off-the-land escalation.

RESOURCES

[TryHackMe – Linux Fundamentals](#)

[GTFOBins Reference](#)

[HackTricks – Linux PrivEsc](#)

DAY 04 — Windows Fundamentals & Registry Essentials

Windows

Learn the Windows registry, services, scheduled tasks, UAC mechanisms, and common misconfigurations that lead to privilege escalation.

RESOURCES

[TryHackMe – Windows Fundamentals 1](#)

[HackTricks – Windows PrivEsc](#)

[PayloadsAllTheThings – Windows PrivEsc](#)

DAY 05 — Networking Foundations for Pentesters

Network

Deep-dive into TCP/IP, DNS, HTTP/S, ICMP, and common ports. Practice with Wireshark and tcpdump to read packet captures and identify recon indicators.

RESOURCES

[TCPDump Cheat Sheet](#)

[Wireshark Official Docs](#)

[TryHackMe – Pre-Security Networking](#)

PHASE 2 // Web Exploitation — OWASP, Injections & Auth Flaws

DAY 06 — Information Disclosure & Version Control Leaks

Web

Identify sensitive data exposed in error messages, hidden directories, .git folders, and debug endpoints. Use tools like git-dumper and dirsearch.

RESOURCES

[PortSwigger – Info Disclosure \(Error Messages\)](#)

[PortSwigger – Version Control History](#)

[PortSwigger – Auth Bypass via Info Disclosure](#)

DAY 07 — Cross-Site Scripting (XSS) — Reflected, Stored & DOM

Web

Work through all three XSS families. Craft payloads that bypass filters, exfiltrate cookies, and weaponize DOM sinks.

RESOURCES

[PortSwigger – Reflected XSS](#)

[PortSwigger – Stored XSS](#)

[PortSwigger – DOM XSS \(document.write\)](#)

[PortSwigger – DOM XSS \(jQuery href\)](#)

DAY 08 — XXE Injection — XML External Entities

Web

Exploit XXE to read local files, perform SSRF, and exfiltrate data via out-of-band channels. Understand how XML parsers are misconfigured.

RESOURCES

[PortSwigger – XXE to Retrieve Files](#)

[PortSwigger – XXE to Perform SSRF](#)

[PortSwigger – XXE via File Upload](#)

DAY 09 — Server-Side Request Forgery (SSRF)

Web

Pivot through the server to reach internal services, metadata endpoints, and cloud credential stores. Bypass filters using open redirects.

RESOURCES

[PortSwigger – SSRF Against Backend System](#)

[PortSwigger – SSRF Against Localhost](#)

[PortSwigger – SSRF Filter Bypass via Open Redirect](#)

DAY 10 — OS Command Injection & SSTI

Web

Chain template injection and command injection to achieve RCE. Test for blind variants using time delays and out-of-band DNS callbacks.

RESOURCES

[PortSwigger – SSTI Basic](#)

[PortSwigger – OS Command Injection \(Simple\)](#)

[PortSwigger – Blind OS Injection \(Time Delay\)](#)

DAY 11 — File Upload Vulnerabilities

Web

Bypass content-type checks, extension filters, and race conditions to upload web shells and achieve remote code execution.

RESOURCES

[PortSwigger – RCE via Web Shell Upload](#)

[PortSwigger – Content-Type Restriction Bypass](#)

[PortSwigger – Race Condition Upload](#)

DAY 12 — JWT Attack Surface

JWT

Web

Exploit unverified signatures, flawed algorithm verification, weak secrets, and header injection attacks (JWK, JKU, KID path traversal, algorithm confusion).

RESOURCES

PortSwigger – JWT Unverified Signature

PortSwigger – JWT Weak Signing Key

PortSwigger – JWK Header Injection

PortSwigger – Algorithm Confusion

DAY 13 — Insecure Deserialization

Web

Modify serialized objects to alter application logic, inject arbitrary objects, and build gadget chains for RCE in PHP and Java applications.

RESOURCES

PortSwigger – Modifying Serialized Data Types

PortSwigger – Arbitrary Object Injection (PHP)

PortSwigger – Custom Java Gadget Chain

DAY 14 — SQL Injection — Manual & Automated

Web

Master UNION-based, error-based, blind boolean, and time-based SQLi. Use sqlmap for automation while understanding every flag you pass.

RESOURCES

PortSwigger – SQL Injection

HackTricks – SQLi Cheat Sheet

SQLMAP Documentation

PHASE 3 // Infrastructure & Active Directory Attacks

DAY 15 — Active Directory Fundamentals

Active Directory

Understand AD objects, trusts, GPOs, Kerberos authentication flow, and common attack vectors before attempting any AD lab.

RESOURCES

TryHackMe – Windows AD Basics

TryHackMe – Breaching Active Directory

HackTricks – Active Directory

DAY 16 — Kerberoasting & AS-REP Roasting

Active Directory

Request service tickets for offline cracking (Kerberoasting) and exploit accounts without pre-auth (AS-REP Roasting) using Impacket and Rubeus.

RESOURCES

[Impacket GetUserSPNs](#)

[HackTricks – Kerberoasting](#)

[PayloadsAllTheThings – Kerberoasting](#)

DAY 17 — Pass-the-Hash, Pass-the-Ticket & NTLM Relay

Active Directory

Windows

Reuse credential material without knowing the plaintext password. Set up Responder and ntlmrelayx to capture and relay NTLM authentication.

RESOURCES

[HackTricks – Pass the Hash](#)

[Responder GitHub](#)

[Impacket ntlmrelayx](#)

DAY 18 — BloodHound — Attack Path Mapping

Active Directory

Enumerate AD with SharpHound, ingest data into BloodHound, and find attack paths to Domain Admin including shortest-path analysis.

RESOURCES

[BloodHound GitHub](#)

[HackTricks – BloodHound](#)

[BloodHound Docs](#)

DAY 19 — Buffer Overflow — Windows (x86 Stack)

Buffer Overflow

Walk through the EIP control, bad-character identification, JMP ESP selection, and shellcode delivery workflow using Immunity Debugger and Mona.py.

RESOURCES

[TryHackMe – Buffer Overflow Prep](#)

[Mona.py Documentation](#)

[Corelan Buffer Overflow Tutorial](#)

DAY 20 — Buffer Overflow — Linux (x86) & ret2libc

Buffer Overflow

Linux

Exploit Linux stack overflows with NX enabled using ret2libc and ROP chains. Understand ASLR bypass techniques.

RESOURCES

[Buffer Overflow Labs \(GitHub\)](#)

[HackTricks – Return to Libc](#)

[LiveOverflow – Binary Exploitation Playlist](#)

DAY 21 — Network Pivoting & Tunneling

Network

Use sshuttle, chisel, ligolo-ng, and socat to pivot through compromised hosts. Understand dynamic port forwarding and reverse tunnels.

RESOURCES

[Chisel GitHub](#)

[Ligolo-ng GitHub](#)

[HackTricks – Tunneling & Port Forwarding](#)

DAY 22 — Credential Hunting & Post-Exploitation

Windows

Linux

Extract credentials from memory (Mimikatz), files, registry, browser stores, and environment variables after gaining initial access.

RESOURCES

[Mimikatz GitHub](#)

[HackTricks – Credentials Post-Exploitation](#)

[LaZagne GitHub](#)

DAY 23 — VulnHub Practice — Beginner Linux Boxes

Linux

Apply recon → enumeration → exploitation → PrivEsc methodology on Vulnhub machines. Focus on note-taking and reproducibility.

RESOURCES

[Rickdiculouslyeasy 1 \(Vulnhub\)](#)

[Kioptrix Level 1.3 \(Vulnhub\)](#)

[Vulnhub Platform](#)

DAY 24 — VulnHub Practice — Intermediate CTF Machines

Linux

Web

Tackle multi-step machines requiring chained exploits. Document every step in a structured report format as if delivering to a client.

RESOURCES

[Mr. R3b0t \(Vulnhub\)](#)

[Bellatrix – Hogwarts \(Vulnhub\)](#)

[Stickyfingers \(Vulnhub\)](#)

PHASE 4 // HTB & Platform Challenges — Real-World Machines

DAY 25 — Hack The Box — Busqueda

Linux

Web

Source code review, Python injection via Searchor, and Docker container escape. Great for understanding supply chain component abuse.

RESOURCES

[HTB – Busqueda](#)

[HTB Platform](#)

DAY 26 — Hack The Box — OnlyForYou

Linux

Web

Exploit a Flask app via LFI, enumerate an internal Neo4j instance, and escalate through pip install to root.

RESOURCES

[HTB – OnlyForYou](#)

DAY 27 — Hack The Box — Escape

Windows

Active Directory

MSSQL credential abuse, NTLM capture with Responder, and Active Directory certificate services (AD CS) exploitation using Certify + Rubeus.

RESOURCES

[HTB – Escape](#)

[Certify GitHub](#)

DAY 28 — Hack The Box — Flight

Windows

Active Directory

NTLM hash capture via file share, lateral movement using RunasCs, and web shell deployment through IIS application pool abuse.

RESOURCES

[HTB – Flight](#)

DAY 29 — Hack The Box — Absolute

Active Directory

Kerberos enumeration without a password, AS-REP roasting, DACL abuse, Shadow Credentials, and KrbRelay for a full AD attack chain.

RESOURCES

[HTB – Absolute](#)

[KrbRelay GitHub](#)

DAY 30 — Hack The Box — Mobile Challenges

Mobile

Reverse Android APKs with jadx, analyze traffic with Burp Suite Mobile Assistant, and exploit insecure data storage and intent vulnerabilities.

RESOURCES

[HTB – Cat Mobile Challenge](#)

[jadx GitHub](#)

[MobSF – Mobile Security Framework](#)

DAY 31 — Hack The Box — Web & Crypto Challenges

Web

Crypto

Work through HTB web and cryptography challenges that require creative chaining of bugs: SSRF, prototype pollution, broken crypto, and hash extension attacks.

RESOURCES

[HTB – SuperMarket Challenge](#)

[HTB – Joker Challenge](#)

[CryptoHack – Cryptography Practice](#)

DAY 32 — Offensive Security Proving Grounds — Intermediate Linux

Linux

Practice on OffSec-managed machines with realistic vulnerabilities. Aim for two machines per session and write clean, reproducible notes.

RESOURCES

[OffSec Proving Grounds](#)

[TJNull OSCP-Like Machines List](#)

DAY 33 — Offensive Security Proving Grounds — Intermediate Windows

Windows

Active Directory

Target Windows machines in OffSec PG. Practice WinRM, SMB enumeration, `SelImpersonatePrivilege` abuse, and token manipulation.

RESOURCES

[OffSec Proving Grounds](#)

[HackTricks – SelImpersonatePrivilege](#)

PHASE 5 // Advanced Topics, Evasion & Capstone Reporting

DAY 34 — OSINT & Reconnaissance Methodology

OSINT

Build a full target profile using passive and semi-passive techniques: WHOIS, certificate transparency, Shodan, TheHarvester, and FOCA metadata extraction.

RESOURCES

[Shodan](#)

[TheHarvester GitHub](#)

[OSINT Framework](#)

DAY 35 — Wireless & Physical Attack Vectors

Network

Survey WPA2 handshake capture, PMKID attacks, evil twin setups, and basic physical security concepts (badge cloning, tailgating awareness).

RESOURCES

[Aircrack-ng Docs](#)

[HackTricks – Wifi Hacking](#)

[Hcxumptool GitHub](#)

DAY 36 — Cloud Security Fundamentals (AWS/Azure)

Network

Web

Identify misconfigured S3 buckets, overly permissive IAM roles, metadata endpoint abuse (IMDS v1), and Azure App Registration exposures.

RESOURCES

[HackTricks – AWS Pentesting](#)

[Pacu – AWS Exploitation Framework](#)

[TruffleHog – Secrets Scanning](#)

DAY 37 — Antivirus & EDR Evasion Concepts

Windows

Understand signature-based vs behavioral detection. Survey obfuscation techniques, process hollowing, AMSI bypass methods, and ETW patching (conceptually).

RESOURCES

[HackTricks – AV Bypass](#)

[AMSI Bypass Reference](#)

[Maldev Academy \(Intro\)](#)

DAY 38 — Digital Forensics for Pentesters

Forensics

Understand artifact residue left by your own tools. Learn Windows event logs, prefetch, LNK files, and memory forensics to improve OPSEC.

RESOURCES

[Autopsy Forensics](#)

[HackTricks – Windows Forensics](#)

[Volatility Memory Forensics](#)

DAY 39 — Custom C2 Infrastructure & Payload Delivery

Windows

Linux

Set up a basic C2 framework (Sliver or Havoc), configure malleable profiles, stage payloads, and establish persistence via scheduled tasks and registry run keys.

RESOURCES

[Sliver C2 GitHub](#)

[Havoc C2 GitHub](#)

[HackTricks – Persistence Techniques](#)

DAY 40 — Full-Scope Report Writing & Capstone Review

Reporting

Capstone

Synthesize a complete penetration test report from your 40-day notes: executive summary, technical findings, CVSS scoring, remediation recommendations, and proof-of-concept evidence. Review tooling gaps and plan your next 30 days.

RESOURCES

[PTES – Penetration Testing Execution Standard](#)

[TCM Security – Report Writing Guide](#)

[OffSec Exam Report Template](#)